# Technical Report (Assignment 6)


```
Name : Ravish Ranjan
Roll no. : 45
Course : MCA
Subject : Information Security
```


## Introduction

**Zero Trust Policy**

Zero Trust is a cybersecurity model based on the principle of “Never Trust, Always Verify.” Unlike traditional security approaches that implicitly trust devices connected to an internal network, Zero Trust requires every access request to be evaluated using relevant identity, security, and contextual information. Here trust is not permanent and it must be re-calculated whenever new situation comes.

Traditional security architectures often assume that devices inside a trusted network are relatively safe. However, this assumption becomes unreliable when devices can be compromised, credentials can be stolen, and network traffic can originate from legitimate but maliciously controlled devices. Zero Trust addresses this limitation by requiring explicit verification and limiting access according to the principle of least privilege.[NIST SP 800-213]

Zero Trust Architecture (ZTA) shifts security away from traditional network perimeters and focuses on protecting individual resources, such as devices, applications, services, and data. Authentication and authorization are performed before access to a resource is established, and access decisions should reflect the current security context rather than relying solely on network location or device ownership.

**Why IoT devices needs continuous trust evaluation**

The Internet of Things (IoT) consists of interconnected physical devices, such as smart cameras, sensors, smart locks, medical monitoring devices, and industrial controllers. These devices collect information, communicate with other systems, and may perform actions that directly affect physical environments. But there ability also brings secuity challenges

IoT environments present several security challenges:

- **Resource constraints**: Many IoT devices have limited processing power, memory, battery capacity, and storage, which can restrict the security mechanisms they can support.
- **Heterogeneous behavior**: Different devices have different normal communication rates, operating schedules, destinations, and security requirements. A packet rate that is normal for a smart TV may be abnormal for a smart lock.
- **Changing security conditions**: A device that behaves normally at one time may later exhibit suspicious traffic, repeated authentication failures, or unexpected communication patterns.
- **Device compromise**: Attackers may exploit vulnerabilities or stolen credentials to control legitimate devices. Successful initial authentication does not guarantee that subsequent activity is safe.
- **Different levels of criticality**: Compromising a medical sensor or smart lock may have more serious consequences than compromising a device with limited access to non-critical data.

[NIST SP 800-213] emphasizes that IoT cybersecurity requirements should be established in the context of organizational and system risk management, considering the capabilities required from devices and the support provided by manufacturers and other parties. This supports evaluating IoT devices according to their security capabilities and the risks associated with their intended use. Consequently, a one-time trust decision is insufficient for environments in which device behavior and risk can change over time. Continuous trust evaluation means periodically re-calculation available security evidence and adjusting access decisions when a device's condition changes.

Consequently, a one-time trust decision is insufficient for environments in which device behavior and risk can change over time. Continuous trust evaluation means periodically re-calculation available security evidence and adjusting access decisions when a device's condition changes.

## IoT Simulation

The practical simulates a IoT environment with different configuration devices in which they generate behavioural and contextual data over time. The simulation is used to evaluate how a Zero-Trust trust-scoring model responds to normal operation, suspicious behaviour, attack-like activity, and subsequent recovery from attack.

Rather than relying on a device's identity alone, the system continuously evaluates its observed behaviour, operating context, historical behaviour, and estimated risk to determine the level of access it should receive.

**Devices**

The simulation models five IoT devices, each with different characteristics, normal activity patterns, operating schedules, and security requirements. Each device is observed over multiple time steps, allowing changes in behaviour and trust to be tracked.

| Device ID | Device type | Normal packet rate (approx.) | Criticality | Scenario |
|---|---|---|---|---|
| D1 | Smart Camera | 120 packets/step | 0.6 | Full attack cycle |
| D2 | Smart Sensor | 10 packets/step | 0.4 | Normal control |
| D3 | Smart Lock | 2 packets/step | 0.9 | Full attack cycle |
| D4 | Smart TV | 200 packets/step | 0.3 | Suspicious behaviour |
| D5 | Medical/Environmental Sensor | 20 packets/step | 1.0 | Full attack cycle |

The packet rates represent synthetic baseline activity rather than measurements from physical devices. Different baseline rates and variability allow the simulation to account for differences between device types.

**Device state and attack senario**

Each device is assigned a state that describes its behaviour at a particular time step. These states provide the ground truth against which the trust model's decisions can be evaluated.

- Normal: The device operates within its expected behavioural pattern.
- Suspicious: The device begins exhibiting deviations that may indicate abnormal activity.
- Attack-like: The device exhibits stronger indicators of potentially malicious activity.
- Recovery: The device's behaviour begins returning towards normal conditions.

This practical implements three scenarios:

| Scenario | Device(s) | State progression |
|---|---|---|
| Normal control | D2 – Smart Sensor | Remains Normal throughout |
| Suspicious behaviour | D4 – Smart TV | Normal -> Suspicious -> Recovery |
| Full attack cycle | D1, D3, D5 | Normal -> Suspicious -> Attack-like -> Recovery |

Each device is simulated for 120 time steps, producing 600 device-time observations across the five devices.

The practical also incorporates CPU usage, memory usage and battery level. These metrics represent the device's resource conditions and help evaluate whether trust assessment can account for resource constraints. In particular, the model reduces the weight assigned to the Behaviour score when the battery level is low. The removed weight is redistributed across the other scoring components so that the total weight remains equal to one. This mechanism represents a simple resource-aware strategy: when resources are constrained, the model changes the relative contribution of its inputs rather than allowing the scoring weights to become invalid.

## Trust Model

The trust model evaluates each IoT device continuously using four components: Behaviour (B), Context (C), History (H), and Risk (R). These components capture different aspects of device activity so that access decisions are not based on a single observation or the device's identity alone. Theses metrics are give my following formulas

**Trust assessment score**

1. Behaviour

$$z = \frac{abs(\text{packet rate} - \text{mean packet rate})}{\text{std. dev. of packet rate}}$$
$$Behaviour(B) = 1 - \frac{z}{5}$$
$$\text{additionaly } Behaviour(B) = B - min(\text{failed logins} * 0.06, 0.3) \text{ (clipped between 0-1)}$$

2. Context

$$Context(C) = 1 - 0.4 * \delta \text{ (clipped between 0-1)}$$
$$\delta = 1, \text{if device operates outside active hours}$$

3. History

$$History(H) = mean(\text{last 10 Behaviour (B) values}) \text{ (clipped between 0-1)}$$

4. Risk

$$Risk(R) = 0.3 * criticality + 0.3 * \text{failed logins} + 0.4 * \text{unauthorized destination of access (clipped between 0-1)}$$

The instantaneous trust assessment score is calculated as:

$$S(t) = w_B B(t) + w_C C(t) + w_H H(t) + w_R(1 - R(t))$$

where:

- B(t): Behaviour score at time t.
- C(t): Context score at time t.
- H(t): History score at time t.
- R(t): Risk score at time t.
- w_B,w_C,w_H,w_R: Weights assigned to the four components.

The term 1-R(t) converts the Risk score into a positive trust contribution. Consequently, a lower risk increases the trust assessment score, while a higher risk decreases it.

The initial weights used in the practical are:

| Component | Weight |
|---|---|
| Behaviour | 0.35 |
| Context | 0.20 |
| History | 0.20 |
| Risk | 0.25 |
| **Total** | **1.00** |

Behaviour receives the highest initial weight because deviations from expected activity are an important indicator of potentially compromised devices. Context and History provide additional evidence, while Risk accounts for suspicious indicators such as failed logins and unauthorised destinations.

**Trust score update**

The instantaneous score may fluctuate as device activity changes. To reduce the effect of isolated fluctuations, the model updates the trust score using exponential smoothing:

$$T(t+1) = \alpha T(t) + (1 - \alpha)S(t)$$

The practical uses $\alpha = 0.7$. This gives the previous trust score greater influence than the latest assessment, smoothing short-term changes while still allowing trust to decline or recover over time. The score is constrained to [0,1].

**Trust-based access decisions**

The updated trust score determines the access decision according to fixed thresholds.

| Trust score | Decision | Interpretation |
|---|---|---|
| $T \geq 0.75$ | ALLOW | Device is permitted normal access |
| $0.50 \leq T < 0.75$ | MONITOR | Device remains accessible under increased observation |
| $0.25 \leq T < 0.50$ | RESTRICT | Device access is limited |
| $T < 0.25$ | ISOLATE | Device is isolated due to low trust |

These thresholds translate a continuous trust score into operational security decisions. A device does not automatically retain full access merely because it was trusted earlier; its decision can change when its trust score crosses a threshold.

**Resource-aware weight adjustment**

The model accounts for low battery conditions by reducing the Behaviour component's weight and redistributing the removed weight across the other components. The adjusted weights are intended to continue summing to one, preserving the validity of the weighted score.

## Experimental Setup

The experiments are designed to test whether the trust model can distinguish normal device behaviour from suspicious activity, respond to attack-like conditions, and reflect recovery over time.

**Simulation configuration**

The practical uses a synthetic dataset generated in Python. Five heterogeneous IoT devices are simulated for 120 time steps each, producing 600 device-time observations. A fixed random seed, np.random.seed(45), is used to make the simulation reproducible.

The main configuration is summarised below.

| Parameter | Configuration |
|---|---|
| Number of devices | 5 |
| Time steps per device | 120 |
| Total observations | 600 |
| Trust components | Behaviour, Context, History, Risk |
| Initial weights | 0.35, 0.20, 0.20, 0.25 |
| Trust smoothing factor | $\alpha = 0.7$ |
| ALLOW threshold | 0.75 |
| MONITOR threshold | 0.50 |
| RESTRICT threshold | 0.25 |
| Resource monitoring | CPU, memory and battery |
| Reproducibility | Fixed random seed of 45 |

**Experimental scenarios**

Four scenarios are used to evaluate different aspects of the model.

1. **Normal operation**: Device D2 acts as a control device and remains in the Normal state throughout the simulation. Its observations help assess whether the model unnecessarily lowers trust for normal activity.

2. **Behavioural deviation**: Device D4 follows a Normal -> Suspicious -> Recovery progression. This scenario tests whether the model responds to deviations without requiring the strongest attack-like indicators.

3. **Attack-like activity**: Devices D1, D3 and D5 undergo Normal -> Suspicious -> Attack-like -> Recovery transitions. This scenario tests whether the model reduces trust when multiple indicators suggest increased risk.

4. **Recovery**: Following suspicious or attack-like activity, devices enter the Recovery state. This scenario examines whether trust rises as simulated behaviour returns towards normal.

**Evaluation metrics**

The following metrics are used to evaluate the trust model.

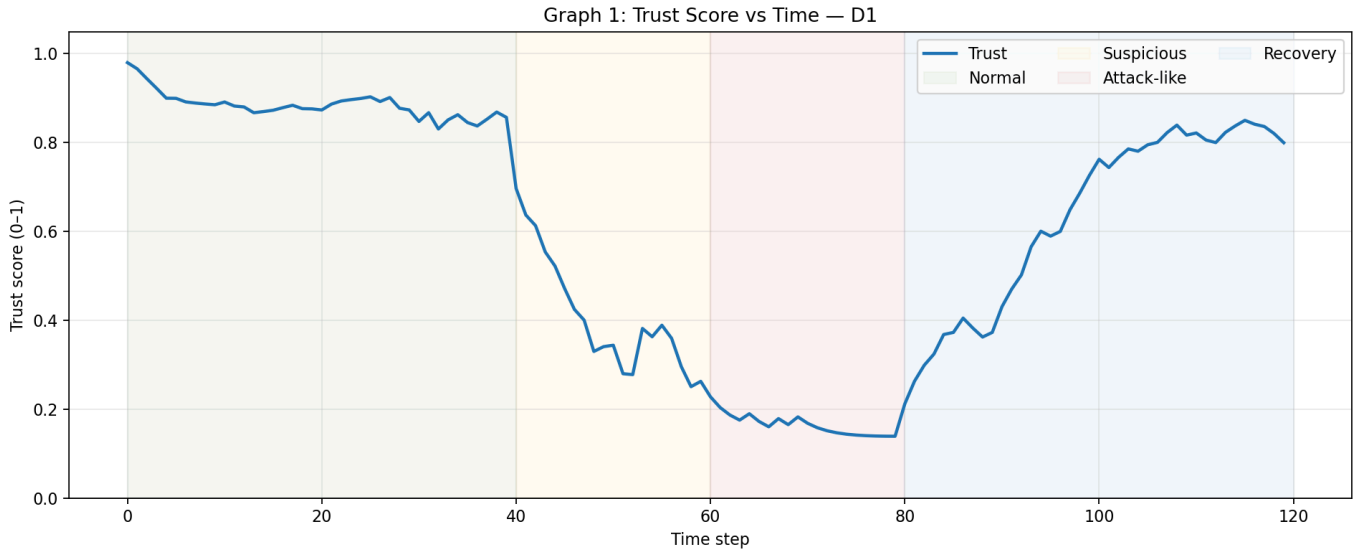
- **Detection Delay**: The number of time steps between the onset of the relevant attack-like condition and the first qualifying restrictive decision. The exact qualifying decision must be defined consistently when calculating the metric.
- **False Restriction Rate**: The proportion of observations for the normal control device D2 in which the model makes a restrictive decision despite the device remaining in the Normal state. The report should specify whether only RESTRICT and ISOLATE count as restrictive decisions.
- **Recovery Time**: The number of time steps from the start of Recovery until the trust score or decision returns to a defined acceptable level. The chosen recovery criterion should be stated explicitly.
- **Trust Stability**: A measure of variation in the trust score over time. For example, the standard deviation of trust during a stable Normal period can be used to quantify fluctuations; lower variation indicates greater stability during that period.

## Results

Following results we captured for device D1 over time-steps

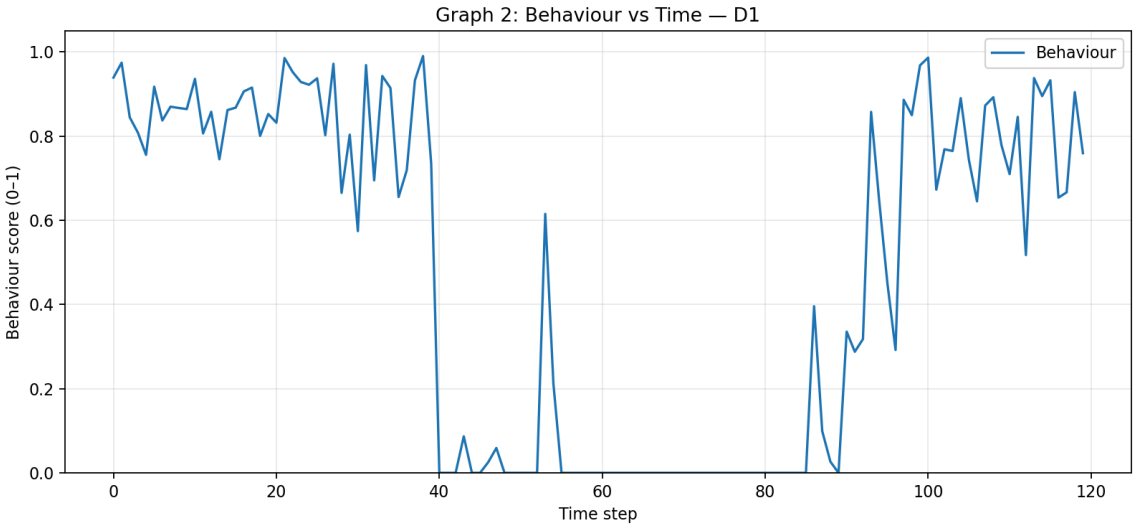
1. Trust of device D1 with time

trust stays stable in normal time, then starts declining during suspicious time and reached trough in attack time. Then it starts rising in recovery time. this is because of drop id different metrics.



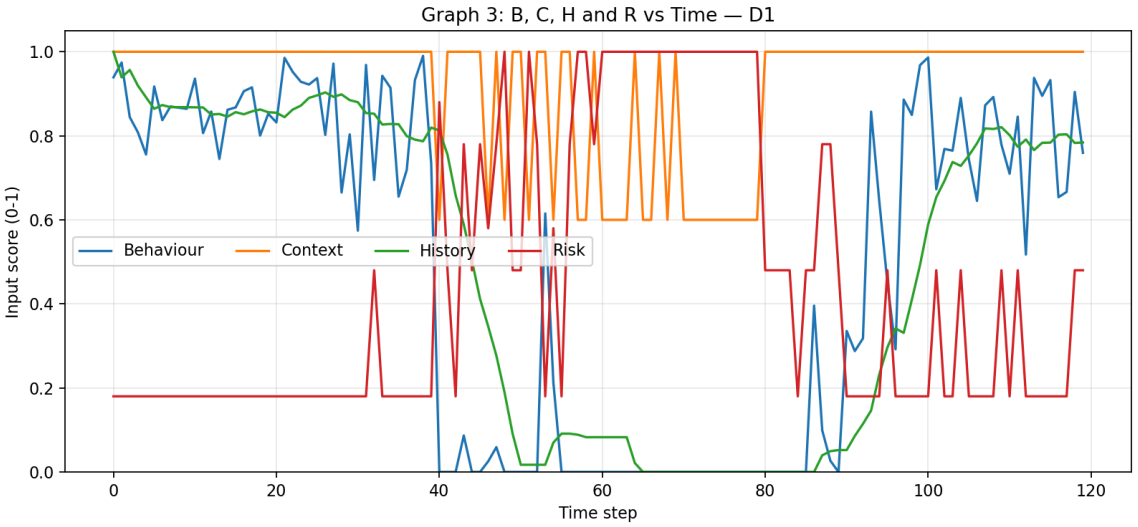

2. Behaviour metric of device D1 over time

Behaviour stays at a level with high variablity at normal time, drop to 0 for most part of suspicious and sttack time and then returns to normal behaviour. This is because of packet rate and failed logins.



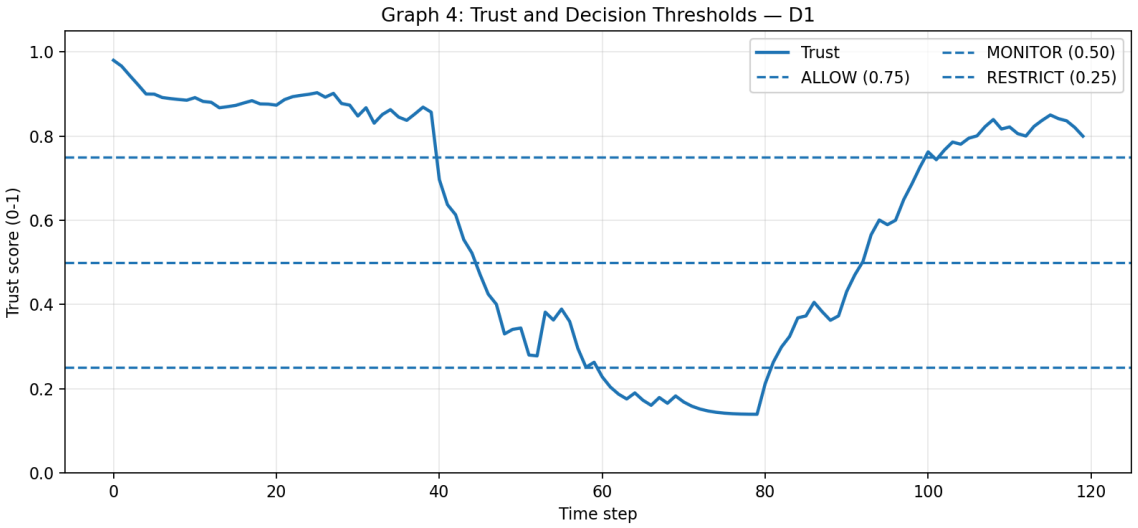

3. Different trust factors for D1 over time

Different metrics follows the expected dip in suspicious and attack time and then risis inrecovery time




4. Trust of device over different trust levels

Trust stays in ALLOWED region in normal time, then drop to MONITOR, RESTRICT and then in ISOLATE as trust declines, says in ISOLATE in attack time and then rises stepwise till ALLOWED in recovery time




## Discussion

The simulation demonstrates how continuous trust evaluation can translate changes in device behaviour into changes in trust scores and access decisions

**Why did trust change?**

Trust is expected to decrease when a device enters Suspicious or Attack-like states because deviations in packet activity and failed login attempts can lower the Behaviour score, while unknown destinations can affect Context and increase Risk. These changes reduce the instantaneous trust assessment score.

When a device enters Recovery, its behaviour gradually returns towards its expected baseline. This can improve its component scores and increase trust. However, trust may recover more slowly than the underlying behaviour because the model incorporates the previous trust score.

The normal control device provides a comparison for determining whether the model maintains trust during normal operation or incorrectly restricts a device.

**Which input dominated?**

The Behaviour component has the largest initial weight, at 0.35, followed by Risk at 0.25, while Context and History each have a weight of 0.20. Therefore, Behaviour has the greatest direct influence among the positively weighted components under the default configuration.

However, the largest weight does not necessarily mean Behaviour dominated every observed trust change. The actual contribution of each component also depends on its score and how much that score changes over time. Risk can have a substantial effect when failed logins or unknown destinations increase the risk score.

**Effect of the smoothing factor ($\alpha$)**

The trust update is defined as:

$$T(t+1) = \alpha T(t) + (1-\alpha)S(t)$$

The smoothing factor controls the balance between previous trust and the latest assessment.

- Higher $\alpha$: Gives more weight to previous trust, producing smoother changes but potentially delaying detection and recovery.
- Lower $\alpha$: Gives more weight to the latest assessment, allowing faster responses but making trust more sensitive to short-term fluctuations.

The practical uses $\alpha = 0.7$. This favours stability while retaining responsiveness to sustained changes.

**Effect of decision thresholds**

The model uses four decisions: ALLOW at trust scores of at least 0.75, MONITOR from 0.50 to below 0.75, RESTRICT from 0.25 to below 0.50, and ISOLATE below 0.25.

These thresholds determine how trust scores translate into access decisions. Higher thresholds for restrictive actions would cause devices to enter those actions at higher trust levels, potentially increasing false restrictions. Lower thresholds could reduce unnecessary restrictions but delay intervention against suspicious devices.

Consequently, threshold selection affects Detection Delay and False Restriction Rate, as well as how quickly devices regain access during recovery.

**Effect of resource constraints**

The practical incorporates CPU, memory and battery measurements. When the battery level is low, the model reduces the Behaviour weight and redistributes the removed weight among the other components.

This adjustment changes the relative contribution of Behaviour to the trust assessment. As a result, trust may respond differently to behavioural deviations under low-battery conditions than it does under normal battery conditions.

## Limitaitons

The practical has several limitations:

1. Simulated data: The device observations are synthetically generated and may not accurately represent the complexity and variability of real IoT network traffic.
2. Manually selected weights: The component weights and trust thresholds are predefined rather than learned from real-world data. Different configurations may produce different decisions and performance metrics.
3. Simplified attack model: Suspicious and Attack-like states follow predefined transitions. Real attacks may be intermittent, gradual or designed to imitate normal device behaviour.
4. Limited device population: The simulation includes only five devices, so its results may not generalise to large IoT networks with diverse devices and communication protocols.
5. Simplified resource awareness: Battery level changes the scoring weights, but the practical does not measure whether this adjustment reduces actual energy consumption or computational overhead.

## Conclusion

The practical implements a continuous trust-scoring model for five heterogeneous IoT devices using Behaviour, Context, History and Risk scores. Exponential smoothing updates trust over time, while predefined thresholds map trust scores to ALLOW, MONITOR, RESTRICT and ISOLATE decisions. A battery-aware adjustment also demonstrates how resource conditions can change the contribution of the scoring components.

The simulation provides a framework for evaluating detection delay, false restrictions, recovery time and trust stability across normal, suspicious, attack-like and recovery scenarios. However, the model's effectiveness must be established using the actual simulation results.